

Proxy Config Security Review

— Status

Revision: 3 **Last modified:** 2026-07-01T14:48:00Z **Status:** Static config-security review of the proxy data plane (Squid forward proxy + Dante SOCKS5). 2 areas already HARDENED (Squid ACL chain, Squid TLS N/A-by-design); 4 Squid header/version-hygiene leaks were FIXED (via, `httpd_suppress_version_string`, `forwarded_for`, `visible_hostname`) — RED→GREEN proven (the Via leak is gone + the security test S3 gate now PASSES); the Dante SSRF/BIND exposure was also FIXED (command: `connect + socks block` for link-local/loopback/RFC1918 — RED→GREEN proven, `dante-log-confirmed`, security-test S4 gate PASS); 2 items remain TRACKED-for-operator because the safe fix carries a connectivity risk requiring an operator decision (Squid `dns_nameservers` DNS-leak in static mode; Dante client-side open-relay — `socksmethod none + client pass from:0.0.0.0/0`). One leak is CONFIRMED live (via); one is INFERRED from Squid defaults and fixed as defense-in-depth (`forwarded_for / X-Forwarded-For`) — the distinction is stated per §11.4.6, no guessing. **Rev 3:** the S3/S4 security guard (`tests/security/proxy_acl_security.sh`) is now WIRED into the standing regression suite (`tests/run-tests.sh test_security_guards`, §11.4.135) with GREEN + RED-polarity, so a header-hygiene or SSRF regression fails the build; and the S4 SSRF verdict was hardened (§11.4.142 independent-review finding) to require dante's own `block(N)` log line as the authoritative §11.4.69 sink-side signal rather than an elapsed-time heuristic (which was bluff-capable on a fast-refusing host). **Authority:** Inherits constitution/Constitution.md per §11.4.35. §11.4.45 integration-status doc for the proxy config-security workstream; §11.4.56 two-audience companion; findings presented as FACTs from a static review (§11.4.6), not re-derived. **Companion:** summary [Status_Summary.md](#)

Operator-blocked / pending items (read first — §11.4.45 O(1) surface)

These three require an operator keep-vs-connectivity decision — the tightest fix would break egress connectivity, so the safe subset is applied now and the full restriction is TRACKED (§11.4.101 — do not autonomously take a connectivity-breaking action).

Item	Why it needs an operator decision	Unblock condition / safe fix candidate
Squid dns_nameservers 8.8.8.8 DNS-leak (static mode)	Re-pointing Squid DNS to the DoT dnspoxy loopback risks breaking name resolution if the dnspoxy is not reachable in that topology. Dynamic mode already mitigates via never_direct.	Operator confirms the dnspoxy loopback is reachable in static mode, then re-point dns_nameservers at it.
Dante SOCKS5 open-relay (socksmethod none + pass from:0.0.0.0/0)	Restricting the client CIDR could cut off legitimate clients on the bridge network.	Operator supplies the trusted client CIDR; then narrow client pass from:. Safe subset (block terminators) applied now.

Findings (static review — §11.4.6 FACTs, not re-derived)

Areas: Squid non-intercepting forward proxy (HTTPS via CONNECT pass-through) + Dante SOCKS5. Severity per user-facing leak/exposure impact. Status vocabulary: **HARDENED** (already safe) · **FIXED** (applied + verified this round) · **TRACKED** (operator decision required, §11.4.101).

#	Area	Finding	Severity	Status
1	Squid — ACL chain	CONNECT locked to 443 via deny CONNECT !SSL_ports; explicit http_access deny all terminator; cache manager localhost-only; fail-closed dynamic profile.	—	HARDENED
2	Squid — TLS	Non-intercepting forward proxy: HTTPS passes through via CONNECT; no https_port / ssl_bump interception surface by design.	—	HARDENED (N
3	Squid — via header	via on leaks Via: 1.1 proxy-squid (squid/6.13) — exposes internal hostname + Squid version.	MED	FIXED (via off)

#	Area	Finding	Severity	Status
4	Squid — version string	httpd_suppress_version_string off leaks the Squid version on generated ERR pages, incl. ERR_TUNNEL_DOWN.	MED	FIXED (httpd_suppress_v on)
5	Squid — forwarded_for	Default forwarded_for emits X- Forwarded-For: with the client LAN IP on plain-HTTP requests — privacy-defeating for a VPN proxy whose purpose is to hide the client.	HIGH	FIXED (forwarded
6	Squid — visible_hostname	visible_hostname absent → Squid falls back to the container id, leaking it on error pages / headers.	LOW	FIXED (visible_ helix-proxy)
7	Squid — dns_nameservers	dns_nameservers 8.8.8.8 bypasses the DoT dnsproxy → DNS leak in static mode (dynamic mode mitigated by never_direct).	MED	TRACKED-for-c
8	Dante — SOCKS5 auth/ client	socksmethod none + client pass from:0.0.0.0/0 + socks pass from:0.0.0.0/0 → open relay if :51080 ever escapes the container bridge.	HIGH	TRACKED
9	Dante — SOCKS5 egress	socks pass to:0.0.0.0/0 with no command: restriction → SSRF to 169.254.169.254 (cloud metadata) / RFC1918, plus BIND allowed.	HIGH	FIXED (command: socks block for 1 169.254/16, 10/8 192.168/16)

#	Area	Finding	Severity	Status
---	------	---------	----------	--------

Directives being applied this round (Squid, findings 3-6)

Four one-line hardening directives land this round; all are pure header/version-hygiene with no connectivity impact:

- `via off` — suppress the `Via` header (finding 3, CONFIRMED live).
- `httpd_suppress_version_string on` — strip the Squid version from ERR pages (finding 4).
- `forwarded_for delete` — drop `X-Forwarded-For` so the client IP is not disclosed on plain HTTP (finding 5, INFERRED — defense-in-depth).
- `visible_hostname helix-proxy` — pin a neutral hostname instead of the container id (finding 6).

References

- Squid directive semantics: [squid-cache.org](https://www.squid-cache.org/Configuration/Configuration) configuration documentation (`via`, `httpd_suppress_version_string`, `forwarded_for`, `visible_hostname`, `dns_nameservers`, `never_direct`).
- Dante SOCKS5 rule semantics: `sockd.conf(5)` (`socksmethod`, `client pass/block`, `socks pass/block`, `command:`, `from:/to:`).
- SSRF exposure class (finding 9): OWASP Server-Side Request Forgery (SSRF) guidance — link-local metadata (169.254.169.254) + RFC1918 destination filtering.

Honest boundary (§11.4.6)

This is a **static configuration** review of the proxy data plane, presented as FACTs (not re-derived here). Exactly one leak is **CONFIRMED** against live captured evidence — the via header (qa-results/security/header_hygiene/red_20260701T133222Z.txt). The forwarded_for / X-Forwarded-For finding is **INFERRED** from Squid's documented defaults and was **not reproduced** (the echo endpoint that would show the reflected header was unreachable at review time); it is fixed as safe defense-in-depth, and this uncertainty is stated rather than asserted as confirmed. Findings 3-6 are being FIXED this round; findings 7-9 are TRACKED because the tightest fix would risk breaking connectivity and therefore needs an explicit operator keep-vs-restrict decision (§11.4.101). This review does not substitute for a live ACL-deny-does-not-leak test (see the hardening workstream's honest security SKIP) nor for the §11.4.40 full-suite retest before a release tag.